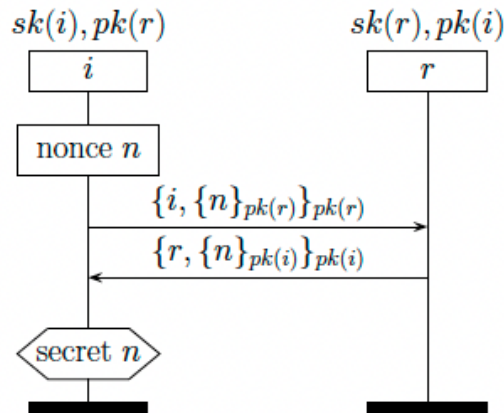


Tutorial Worksheet C

Description. This tutorial worksheet covers security protocol analysis. You will analyze the security of various security protocols and try to find attack scenarios that compromise the security claims of the protocols.

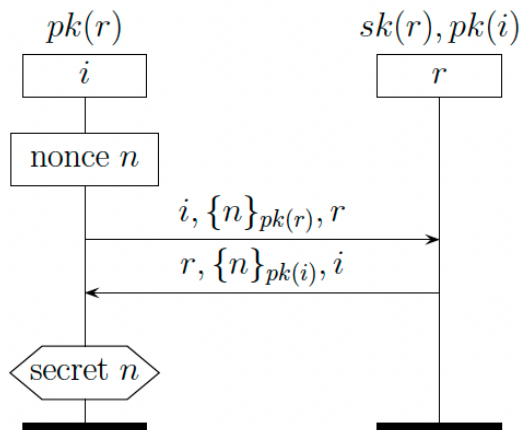
Exercise 1

Consider the following “Double encryption” security protocol that allows two parties, i and r to share a secret n . Find an attack scenario where a third, unauthorized party, manage to disclose the secret n . The parameters $sk(x)$ and $pk(x)$ represent the private and public key of the communication party x , respectively. The value n is a nonce (number used once).



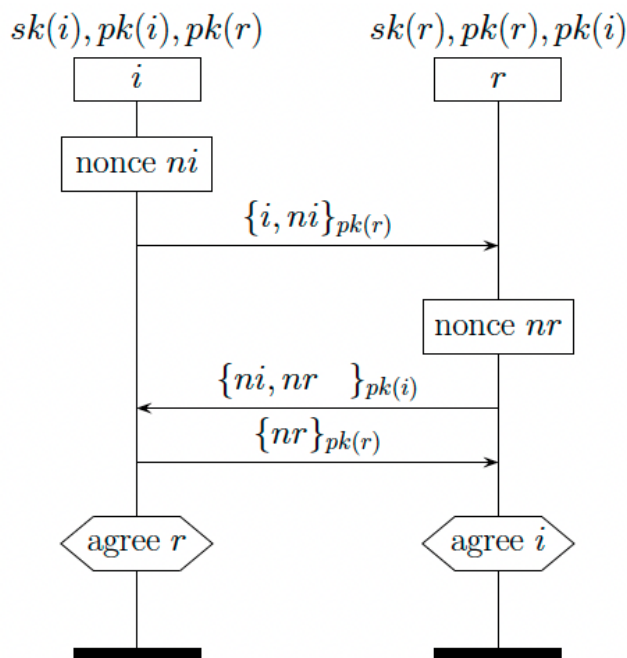
Exercise 2

Consider the following security protocol where two parties, i and r , establish a share a secret n . Find an attack scenario where a third, unauthorized party, manage to disclose the secret n . The parameters $sk(x)$ and $pk(x)$ represent the private and public key of the communication party x , respectively. The value n is a nonce (number used once).



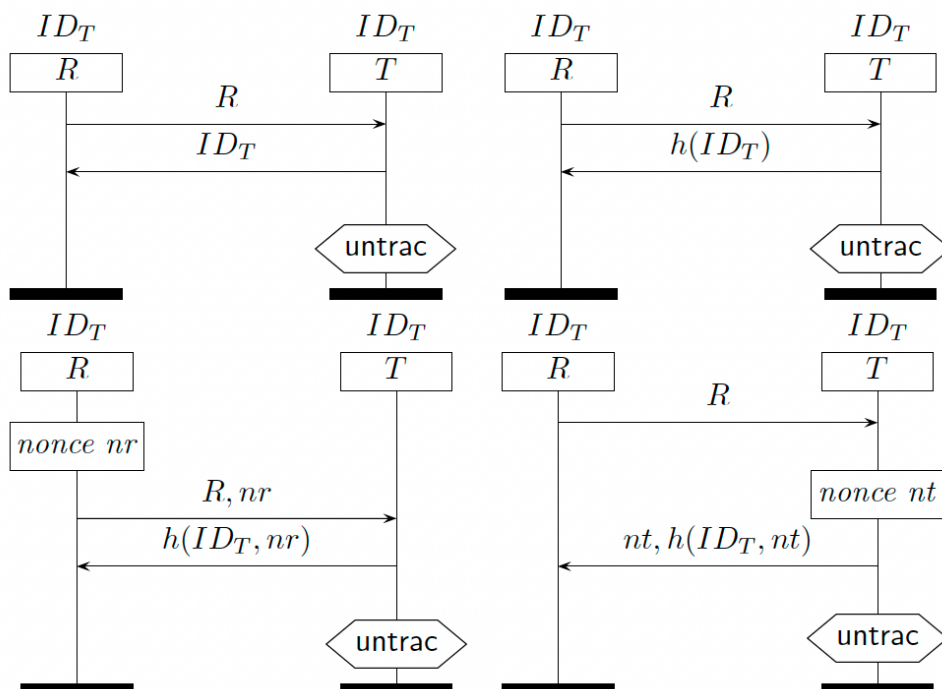
Exercise 3

Consider the following Needham-Schroeder protocol, where two communication parties, i and r , secretly exchange and agree upon nonces, n_i and n_r . Find an attack scenario where an adversary manage to disclose the secret nonces. Propose a fix to the protocol.



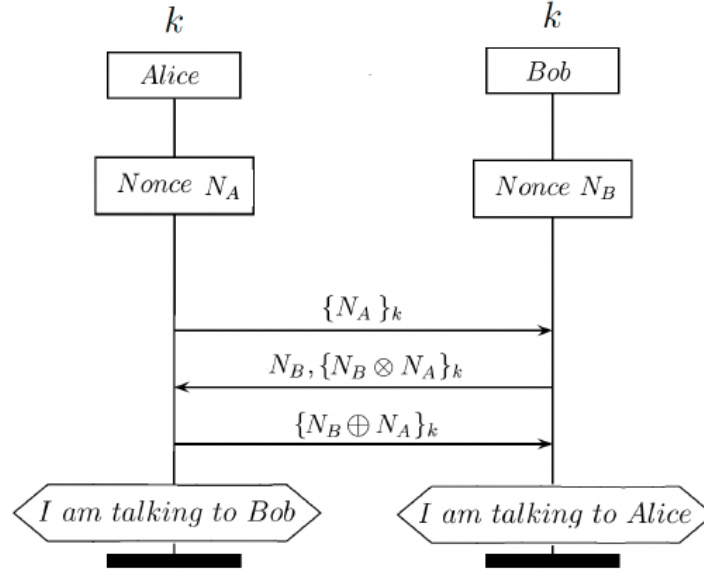
Exercise 4

Consider the following four RFID authentication protocols, where an RFID reader R interrogates an RFID tag T for identification. Which among the four protocols provides untracability? Explain.



Exercise 5

Suppose that Alice and Bob want to securely communicate using a protocol as described by the MSC shown below. The two communication parties have to authenticate each other (mutual authentication), and to do that, each party must prove to the other one that they have the correct pre-shared symmetric key ($k = k^{-1}$) without sending it. After sending the last message, both parties claim to communicate with the right communication party. Can Charlie authenticate himself as Alice or Bob without having the key k and break the two claims (“I am talking to Alice” and “I am talking to Bob”)? Explain.



Exercise 6

Consider a PUF-based security protocol for smart meters in the context of smart grid applications. The protocol allows a smart meter to be authenticated to a server using PUFs. During the authentication of the smart meter to the server, the smart meter initiates the authentication by sending an authentication request. Based on the source of the request, the server retrieves from the database a cryptographic information, denoted by $\sigma = (C, \sigma_1, \sigma_2)$. This information contains the challenge C as well as two values, σ_1 and σ_2 . The value of σ_1 was generated during the enrolment phase as $\sigma_1 = \mathcal{E}_{sk_A}(\alpha_2)$, where $sk_A = \mathcal{H}(\Psi(C))$ is the secret key of the smart meter, $\alpha_2 = \mathcal{H}(sk_{id}|C|A)$, A the identity of the smart meter, sk_{id} the secret key of the server, $\Psi(\cdot)$ is the smart meter PUF function, and $\mathcal{H}(\cdot)$ is a hash function. The server sends to the meter the value of σ along with a random nonce n . The meter receives σ and n and uses the challenge C contained in σ to compute the response $R = \Psi(C)$. It also compute the values: $sk_A = \mathcal{H}(R)$, $\alpha_1 = \mathcal{H}(sk_A id)$, $\alpha'_2 = \mathcal{D}_{sk_A}(\alpha_1)$, $\beta_1 = \mathcal{H}(\alpha_1 | \alpha'_2 | n + 1)$. The meter then sends to the server the value β_2 to prove its identity. In the mean time, the server computes the values: $\alpha'_1 = \mathcal{D}_{sk_A}(\alpha_2)$, $\alpha_2 = \mathcal{H}(sk_A, | C | A)$, $\gamma_1 = \mathcal{H}(\alpha'_1 | \alpha_2 | n)$, and $\beta_2 = \mathcal{H}(\alpha'_1 | \alpha_2 | n + 1)$. Upon receiving the value of β_2 from the meter, the server sends the value of γ_1 to the meter. The meter checks whether $\beta_1 = \gamma_1$ to claim that the server is authenticated. Similarly, the server checks whether $\beta_2 = \gamma_2$ to claim that the meter is authenticated. These two authentication claims take place after an

acceptation messages is sent by the meter to the server, and the latter replied back with an acknowledgement.

Next, both authenticating parties start the key establishment phase which is based on Diffie-Hellman Key Exchange Protocol. Both parties first compute the value $g = \mathcal{H}'(\alpha_1 \mid \alpha_2)$. The meter and the server generate the value $x \in \mathbb{Z}_q$ and $y \in \mathbb{Z}_q$, respectively, and send to each other the value of $g^x = \mathcal{H}'(\alpha_1 \mid \alpha_2)^x$ and $g^y = \mathcal{H}'(\alpha_1 \mid \alpha_2)^y$. The meter receives the value of g^y and raise it to the power of x to compute the session key $K = \mathcal{H}'(\alpha_1 \mid \alpha_2)^{x \cdot y}$. Similarly, the server receives the value g^x and raise it to the power of y and compute the same key $K = \mathcal{H}'(\alpha_1 \mid \alpha_2)^{y \cdot x}$. At this point both authenticating parties claim that the shared key has been established. The authentication and key establishment of the protocol are illustrated in the below MSC.

Find an attack scenario that compromises both security claims (hint: spoofing attack).

